بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

Computer Security:
Principles and Practice,Fourth Edition

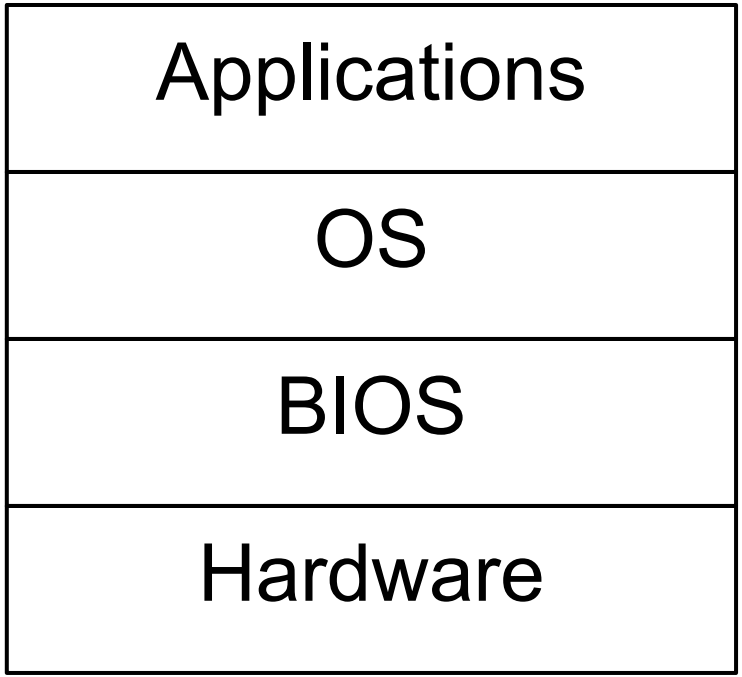
By: William Stallings and Lawrie Brown

Chapter 12

Operating System Security

Each layer is vulnerable to attack from below, should the lower layers not also be secured appropriately.

Each of these layers of code needs appropriate **security hardening**



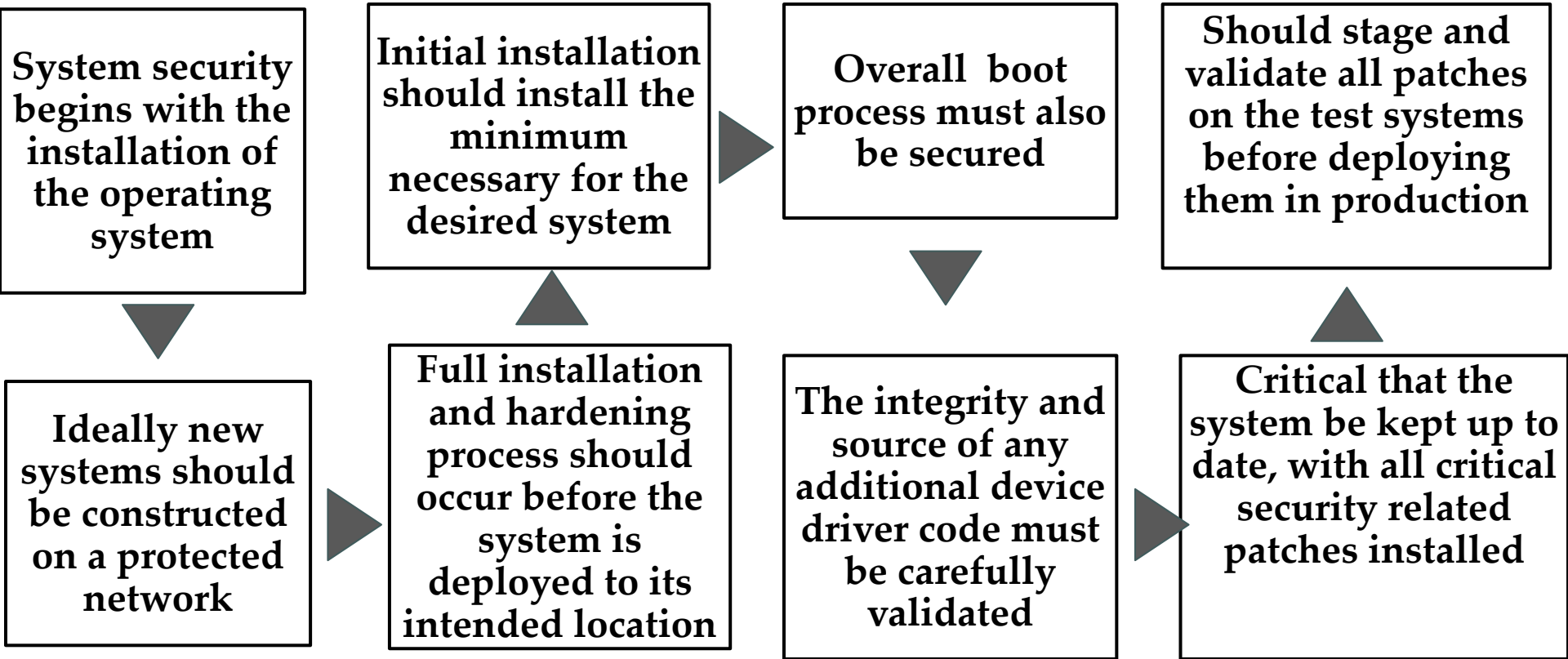
OS Prevention Strategies

- Over 85% of the targeted cyber intrusions investigated by Australian Signals Directorate (ASD) in 2009 could have been prevented by OS security
- The top four strategies for prevention are:
  - White-list approved applications
  - Patch third-party applications and operating system vulnerabilities
  - Restrict administrative privileges
  - Create a defense-in-depth system

OS Hardening Steps

- Install and patch the operating system
- Harden and configure the operating system to adequately address the identified security needs of the system by:
  - Removing unnecessary services, applications, and protocols
  - Configuring users, groups, and permissions
  - Configuring resource controls
- Install and configure additional security controls, such as anti-virus, host-based firewalls, and intrusion detection system (IDS)
- Test the security of the basic operating system to ensure that the steps taken adequately address its security needs

Initial Setup and Patching



Remove Unnecessary Services, Applications, Protocols

- If fewer software packages are available to run the risk is reduced
- System planning process should identify what is actually required for a given system

Better to not instal unwanted software, rather than installing and then removing or disabling it. As:

- Uninstall scripts can fail to completely remove all components of a package.
- Disabling a service means that while it is not available as an initial point of attack, upon successful intrusion, it could be re-enabled to further compromise a system

- When performing the initial installation the supplied defaults should not be used
  - Default configuration is set to maximize ease of use and functionality rather than security
  - If additional packages are needed later they can be installed when they are required

Configure Users, Groups, and Authentication

- Not all users with access to a system will have the same access to all data and resources on that system
- Elevated privileges should be restricted to only those users that require them, **and then only when they are needed to perform a task**

Once the users and their associated groups are defined, appropriate **permissions** can be set on data and resources to match the specified policy. **E.g. to limit which users can :**

- **execute some programs, especially those that modify the system state.**
- **read or write data in certain directory trees.**

- System planning process should consider:
  - Categories of users on the system
  - Privileges they have
  - Types of information they can access
  - How and where they are defined and authenticated
- Default accounts included as part of the system installation should be secured
  - Those that are not required should be either removed or disabled
  - Policies that apply to authentication credentials configured

Install Additional Security Controls

- Further security possible by installing and configuring additional security tools:
  - Anti-virus software
  - Host-based firewalls
  - IDS or IPS software
  - Application white-listing (This limits the programs that can execute on the system to just those in an explicit list. it functions best in an environment with a predictable set of applications that users require. Any change in software usage would require a change in the configuration)

Security Maintenance

- Process of maintaining security is continuous
- Security maintenance includes:
  - Monitoring and analyzing logging information
  - Performing regular backups
  - Recovering from security compromises
  - Regularly testing system security
  - Using appropriate software maintenance processes to patch and update all critical software, and to monitor and revise configuration as needed

Logging

Can only inform you about bad things that have already happened

In the event of a system breach or failure, system administrators can more quickly identify what happened

Key is to ensure you capture the correct data and then appropriately monitor and analyze this data

Information can be generated by the:

1. **System:**
2. **Network**
3. **Applications (e.g server apps)**

Range of data acquired should be determined during the system planning stage

Generates significant volumes of information and it is important that sufficient space is allocated for them

Automated analysis is preferred (e.g. IDS)

Data Backup and Archive

Performing regular backups of data is a critical control that assists with maintaining the integrity of the system and user data

- May be legal or operational requirements for the retention of data

Backup

- The process of making copies of data at regular intervals

Archive

- The process of retaining copies of data over extended periods of time in order to meet legal and operational requirements to access past data

Needs and policy relating to backup and archive should be determined during the system planning stage

- Kept online or offline
- Stored locally or transported to a remote site
  - Trade-offs include ease of implementation and cost versus greater security and robustness against different threats

Linux/Unix Application and Service configuration

- Most commonly implemented using separate **config (text)** files for each application and service
- Generally located either in the **/etc** directory or in t**he installation tree for a specific application**
- Individual user configurations that can override the system defaults are located in **hidden "dot" files in each user's home directory**
- Most important changes needed to improve system security are to **disable services and applications that are not required**

Example App configs

#Security

PermitRootLogin no

PasswordAuthentication no

#Network

port = 3306

bind-address = 127.0.0.1

#Files management

DocumentRoot "/var/www/html"

ErrorLog "/var/log/httpd/error.log"

#System

shared_buffers = 256MB

max_connections = 100

Linux/Unix Patch management

Keeping security patches up to date is a widely recognized and critical control for maintaining security

It is important to configure whichever update tool is provided on the distribution in use, to install at least critical security patches in a timely manner.

- Red Hat, Fedora, and CentOS include **up2date** or **yum**
- SuSE includes **yast**;
- Debian uses **apt-get** ,

though you must run them as a cron job (scheduled task) for automatic updates.

Linux/Unix: Users, groups, and permissions

- Access (for files and directories) is specified as granting **read, write, and execute** permissions to each of owner, group, and others for each resource
- Usually set using the **chmod** command
- Information on user accounts and group membership are traditionally stored in the **/etc/passwd** and **/etc/group files**,
- Can also import these details from external repositories queried using Lightweight Directory Access Protocol (**LDAP**)

Windows Application and service configuration

- Much of the configuration information is centralized in the **Registry**
  - Forms a database of keys and values that may be queried and interpreted by applications
- Registry keys can be directly modified using the "Registry Editor"
  - More useful for making bulk changes

Windows Security

Patch management

- "**Windows Update**" and "**Windows Server Update Service**" assist with regular maintenance and should be used
- Third party applications also provide automatic update support

Users administration and access controls

- Users and groups in Windows systems are defined with a **Security ID** (SID).
- This information may be stored and used locally, on a single system, in the **Security Account Manager** (SAM).
- It may also be centrally managed for a group of systems belonging to a domain, with the information supplied by a central **Active Directory** (AD) system using the LDAP protocol.
- These systems can also enforce common policy on users on any system in the domain.